

EGR6301 — Етичний хакінг

Лабораторна робота 1: Налаштування середовища та перше мережеве сканування

Тиждень 1
Орієнтовний час: 90 хвилин
Максимальний бал: 100
Інструменти: VirtualBox 7.x, Kali Linux VM (надається), Metasploitable 2 VM (надається)
Здача: PDF-звіт зі скріншотами, формат назви: Lab1_Прізвище_Група.pdf
Викладач: Тетяна Василівна Бабенко, д.т.н., професор

Цілі навчання

1. Встановити та налаштувати VirtualBox з Host-Only мережевим адаптером для ізолизованого тестування
2. Імпортувати та перевірити попередньо налаштовані віртуальні машини Kali Linux та Metasploitable 2
3. Перевірити мережеву зв'язність між атакуючою та цільовою машинами за допомогою ping та ip addr
4. Виконати базове сканування виявлення хостів Nmap та інтерпретувати результати
5. Виконати сканування версій сервісів (nmap -sV) та ідентифікувати запущені сервіси
6. Проаналізувати вивід Nmap для створення структурованої таблиці сервісів
7. Ідентифікувати щонайменше один потенційно вразливий сервіс на основі інформації про версію
8. Здокументувати всі дії скріншотами та письмовими поясненнями згідно з практиками професійної звітності

Частина 1 — Концептуальні основи (25 балів)

Дайте відповіді на наступні питання. Покажіть хід міркувань. Мінімум 3–4 речення на відповідь, якщо не вказано інше.

Завдання 1.1 — Мережева ізоляція (5 балів)

Поясніть, чому лабораторії тестування на проникнення повинні використовувати ізолизовану мережу (наприклад, Host-Only), а не NAT або Bridged адаптер. Які конкретні ризики виникнуть, якщо лабораторні VM будуть підключені до університетської мережі або інтернету? Опишіть щонайменше два конкретних сценарії, де відсутність ізоляції може спричинити юридичні або технічні проблеми.

Завдання 1.2 — Методологія сканування (5 балів)

Тестувальник на проникнення має наступний вивід Nmap:

```
PORT      STATE SERVICE 21/tcp    open  ftp      22/tcp    open  ssh      80/tcp    open  http
3306/tcp  open  mysql
```

Тестувальник одразу запускає Metasploit проти порту 21. Згідно з методологією PTES, яку фазу пропустив тестувальник? Чому це проблема? Що він повинен був зробити між скануванням та експлуатацією?

Завдання 1.3 — Аналіз авторизації (5 балів)

Ви готуєте тест на проникнення для компанії. Вони надсилають вам email: «Не соромтесь тестувати наші сервери за адресою 10.0.1.0/24. Ми вам довіряємо.» Чи є це достатньою юридичною авторизацією?

Перерахуйте чотири ключових документи, які потрібні професійному пентестеру перед початком будь-якого тестування, та поясніть призначення кожного.

Завдання 1.4 — Визначення версій (5 балів)

Поясніть різницю між базовим SYN-скануванням Nmap (`nmap -sS target`) та скануванням версій сервісів (`nmap -sV target`). Який додатковий мережевий трафік генерує `-sV`? Чому визначення версій є критичним для фази аналізу вразливостей PTES? Проілюструйте відповідь на прикладі `vsftpd 2.3.4`.

Завдання 1.5 — Класифікація хакерів (5 балів)

Прочитайте три сценарії та класифікуйте кожну особу як White Hat, Grey Hat або Black Hat. Обґрунтуйте кожну класифікацію 2–3 реченнями.

Сценарій А: Аліса виявляє SQL-ін'єкцію на сайті свого банку під час перевірки рахунку. Вона пише детальний звіт і надсилає його команді безпеки банку. Вразливість не експлуатує.

Сценарій Б: Борис використовує Nmap для сканування Wi-Fi роутера сусіда, щоб «перевірити, чи він захищений». Знаходить відкриту панель адміністратора і змінює пароль, щоб «захистити» сусіда. Дозволу не має.

Сценарій В: Кароліна найнята за контрактом лікарнею для тестування системи медичних записів пацієнтів. Дотримується Score of Work, документує все та подає професійний звіт.

Частина 2 — Практичні термінальні завдання (45 балів)

Виконайте всі завдання у вашому лабораторному середовищі. Для кожного завдання надайте скріншот з командою ТА її результатом. Напишіть коротке пояснення (2–3 речення) того, що означає кожен результат.

Завдання 2.1 — Налаштування VirtualBox та VM (10 балів)

- Імпортуйте обидві VM — Kali Linux та Metasploitable 2 — у VirtualBox. Зробіть скріншот менеджера VirtualBox з обома машинами.
- Налаштуйте Host-Only мережевий адаптер (`vboxnet0`). VirtualBox → File → Host Network Manager → Create. Переконайтесь, що DHCP увімкнено або налаштуйте статичні IP: - Kali Linux: 192.168.56.102 - Metasploitable 2: 192.168.56.101
- Запустіть обидві VM. У Kali відкрийте термінал і виконайте: `ip addr show eth0` Зробіть скріншот з присвоєною IP-адресою.
- У Metasploitable 2 увійдіть (`msfadmin / msfadmin`) та виконайте: `ifconfig` Зробіть скріншот з IP-адресою.

Завдання 2.2 — Перевірка з'єднання (5 балів)

З терміналу Kali Linux перевірте з'єднання з Metasploitable 2:

```
ping -c 4 192.168.56.101
```

Зробіть скріншот. Поясніть: що підтверджує «4 packets transmitted, 4 received, 0% packet loss»? Що ви перевірите, якщо ping не працює?

Завдання 2.3 — Базове виявлення хостів (10 балів)

Запустіть сканування виявлення хостів у всій підмережі:

```
nmap -sn 192.168.56.0/24
```

- Зробіть скріншот повного виводу.
- Перерахуйте всі виявлені хости в таблиці (IP-адреса, статус, причина).
- Поясніть: що робить прапорець `-sn`? Чим він відрізняється від повного сканування портів? Чому пентестер використовує це як перший крок?

Завдання 2.4 — Виявлення версій сервісів (10 балів)

Запустіть сканування версій сервісів Metasploitable 2:

```
nmap -sV 192.168.56.101
```

- Зробіть скріншот повного виводу.
- Створіть таблицю карти сервісів з колонками: Порт | Протокол | Стан | Сервіс | Версія Заповніть ВСІ виявлені сервіси (очікується 10+ записів).
- Виділіть будь-який сервіс, де номер версії вказує на можливу застарілість або вразливість. Поясніть ваші міркування щонайменше для двох сервісів.

Завдання 2.5 — Сценарій усунення несправностей (5 балів)

Змодельуйте проблему зв'язності. У VirtualBox змініть мережевий адаптер Metasploitable 2 з «Host-Only» на «NAT». Потім з Kali виконайте:

```
ping -c 2 192.168.56.101      nmap -sn 192.168.56.101
```

Зробіть скріншоти обох результатів.

а) Поясніть, чому ping не працює. б) Що пентестер зробив би з таким результатом Nmap? с) Відновіть адаптер на Host-Only та перевірте відновлення зв'язності. Зробіть фінальний скріншот успішного ping.

Завдання 2.6 — Визначення ОС (5 балів)

Запустіть сканування визначення ОС:

```
sudo nmap -O 192.168.56.101
```

Зробіть скріншот. Яку ОС ідентифікує Nmap? Наскільки Nmap впевнений (шукайте 'OS details' або 'Aggressive OS guesses')? Чому визначення ОС може бути корисним під час фази Intelligence Gathering?

Частина 3 — Методологія та аналіз поверхні атаки (20 балів)

Дайте відповіді на питання на основі результатів сканування з Частини 2. Посилайтесь на конкретні дані з виводу Nmap.

Завдання 3.1 — Відображення фаз PTES (10 балів)

Використовуючи карту сервісів із Завдання 2.4, відобразіть лабораторні дії на фази PTES:

а) Яку фазу PTES ви виконали в Завданнях 2.1–2.2? Яка її мета? б) Яку фазу PTES ви виконали в Завданнях 2.3–2.6? Яка її мета? с) На основі результатів сканування, які НАСТУПНІ дві фази PTES? Для кожної опишіть одну конкретну дію з посиланням на конкретний сервіс. d) Чому фаза Reporting є обов'язковою навіть у лабораторній роботі?

Завдання 3.2 — Аналіз поверхні атаки (10 балів)

На основі повного виводу Nmap:

- а) Визначте ТРИ сервіси з найвищим ризиком безпеки. Для кожного поясніть: - Який сервіс та версія запущені? - Чому цей сервіс потенційно вразливий? - Який тип атаки можливий? (backdoor, brute-force, web exploit тощо)
- б) Якби ви писали професійний звіт пентесту, як би ви пріоритизували ці три знахідки? Використайте оцінки ризику High / Medium / Low та обґрунтуйте кожну.
- с) Для знахідки з найвищим ризиком знайдіть номер CVE (можете використати браузер Kali або опис CVE з лекції). Запишіть CVE ID та опис вразливості одним реченням.

Частина 4 — Безпека та професійна перспектива (10 балів)

Дайте відповіді в контексті професійного тестування на проникнення.

Завдання 4.1 — Аналіз етичних меж (5 балів)

Під час лабораторного сканування ви виявили, що Metasploitable 2 має багато вразливих сервісів. У реальному тесті на проникнення:

а) Що ви зробите, якщо випадково виявите сервіс ЗА МЕЖАМИ вашого авторизованого scope, який, здається, містить критичні медичні дані пацієнтів? б) Які конкретні документи регулюватимуть ваші дії в цій ситуації? с) Який правильний професійний порядок дій? Опишіть кроки.

Завдання 4.2 — Рекомендації з захисту (5 балів)

На основі результатів сканування напишіть коротку секцію «Рекомендації» як для реального звіту пентесту. Для трьох виявлених сервісів:

а) Вкажіть знахідку (назва сервісу, версія, порт). б) Поясніть ризик нетехнічною мовою (як для CEO). с) Рекомендуйте конкретну дію з усунення.

Приклад: Знахідка: vsftpd 2.3.4 на порту 21/tcp Ризик: Цей FTP-сервер містить відомий backdoor, який дозволяє зловмиснику отримати повний контроль. Рекомендація: негайно оновити vsftpd до останньої стабільної версії або вимкнути FTP, якщо він не потрібен.

Критерії оцінювання

Компонент	Бали	Критерії
Частина 1 — Концептуальні основи	25	Коректність міркувань, глибина пояснень, посилання на PTES/правові концепції
Частина 2 — Практичні завдання	45	Правильні команди, чіткі скріншоти, кроки верифікації, аналіз усунення несправностей
Частина 3 — Методологія	20	Точність відображення PTES, якість аналізу атаки, ідентифікація CVE
Частина 4 — Безпека	10	Етичне мислення, якість звіту, рекомендації з захисту
РАЗОМ	100	

Інструкції з подання

- ▶ Формат файлу: один PDF-документ
- ▶ Назва файлу: Lab1_Прізвище_Група.pdf (напр., Lab1_Іванов_КБ401.pdf)
- ▶ Зміст: всі відповіді, ВСІ скріншоти (з командою + виводом), таблиця карти сервісів
- ▶ Скріншоти повинні бути читабельними — повне вікно терміналу, не обрізані фрагменти
- ▶ Подати через Teams до дедлайну, вказаного в розкладі курсу
- ▶ Пізня здача: -10% за кожен день, максимум 3 дні запізнення